B BELLOMASSI

SECURITY AND COMPLIANCE

Security Requirements Document

Bellomassi Order-to-Delivery Management Platform

Document ID BM-SEC-001

Document control

Field	Value
Document title	Security Requirements Document
Document ID	BM-SEC-001
Version	1.0
Status	Draft — for client review
Category	Security and Compliance
Related module(s)	All modules
Document owner	Security Architect
Prepared by	Project documentation team (AI-assisted draft prepared from source-code analysis)
Reviewed by	*Pending — not yet reviewed*
Approval	*Not approved — awaiting client review (no approval has been given)*
Created date	2026-11-12
Last updated date	2026-11-12

> **Status labels used in this document:** VERIFIED (confirmed in the current source code or existing documents) · PROTOTYPE (works in the React/LocalStorage prototype with mock or simulated behaviour) · PROPOSED (recommended production design, not built) · PENDING CONFIRMATION (needs a client decision) · NOT IMPLEMENTED · NOT VERIFIED.

Purpose

State the security requirements for the production platform and the actual security status of the prototype.

Scope

Authentication, authorisation, data protection, integrations, files, OTP, POD, logging, operations. Sensitive data — customer data, credit information, orders, delivery addresses, driver information, OTPs, POD, invoices, uploaded files, permissions, financial data.

Definitions

Other terms: see **BM-GLO-001** (Project Glossary).

References

- **BM-SEC-002** (Security Architecture)
- **BM-SEC-003** (Authentication, Password, MFA and Session Management Design)

- **BM-SEC-004** (Authorization and RBAC Design)
- **BM-SEC-006** (Data Protection, Encryption and Backup Security Policy)
- **BM-SEC-009** (File Upload, OCR, OTP, Email and OpenWA Security)
- **BM-SEC-011** (Vulnerability Management and Security Testing Plan)
- **BM-SEC-012** (Security Risk Register)
- **BM-SYS-004** (Non-Functional Requirements)

1. Current security status — prototype (VERIFIED)

> **The prototype has no real security.** Data lives unencrypted in the browser; demo passwords are published; the session and the permission checks run in the browser and can be bypassed with developer tools. It must not hold real customer or financial data.

Control	Prototype	Label
Authentication	Demo users, FNV-1a hash in LocalStorage, lockout and idle timeout simulated	PROTOTYPE
Authorisation	`can(user, key)` in services + route guards (client-side)	PROTOTYPE
Data at rest	Plain JSON in LocalStorage	NOT IMPLEMENTED
Transport	Depends on how the static build is served	NOT VERIFIED
Audit	Audit log of admin / security events (browser)	PROTOTYPE
File handling	Images / documents as data URLs, size-limited	PROTOTYPE
OTP	6-digit code stored in plain text, shown in customer app	PROTOTYPE

2. Security requirements — production (PROPOSED)

ID	Requirement	Area
SEC-REQ-01	All traffic over TLS 1.2+ (HTTPS, WSS); HSTS	Transport
SEC-REQ-02	Passwords hashed with Argon2id; password policy (min 10, breached-password check)	Authentication
SEC-REQ-03	JWT access tokens ≤ 15 min, rotating refresh tokens, revocation on logout / password change	Session
SEC-REQ-04	MFA (TOTP) mandatory for Super Admin, Administrator, Finance	Authentication
SEC-REQ-05	Lockout after 5 failures (configurable), rate limiting per IP / account	Authentication
SEC-REQ-06	Server-side permission check on every endpoint using the 110 keys; object-level scope	Authorisation
SEC-REQ-07	Customers see only their own orders, tracking, documents; drivers only their deliveries	Authorisation
SEC-REQ-08	Encryption at rest for database, backups and object storage; field-level encryption for tax IDs and phone numbers optional	Data

ID	Requirement	Area
SEC-REQ-09	OTP hashed, 10-minute expiry, 5 attempts, rate-limited regeneration, never returned to the driver	OTP
SEC-REQ-10	Uploaded files: type and size checks, virus scan, stored outside the web root, served by signed URLs	Files
SEC-REQ-11	Audit log append-only, includes user, action, before / after, IP; retained 7 years	Audit
SEC-REQ-12	Secrets in a secrets manager; none in source code or the browser	Operations
SEC-REQ-13	Dependency, SAST, container image scanning in CI; penetration test before go-live	Assurance
SEC-REQ-14	Location tracking only during active deliveries; visible indicator; customers never see fleet	Privacy
SEC-REQ-15	Webhooks signed and verified; outbound egress allow-list	Integrations
SEC-REQ-16	Backups encrypted, restore tested quarterly	Resilience
SEC-REQ-17	Security logging and alerting (failed logins, privilege changes, mass export)	Monitoring
SEC-REQ-18	Personal data minimised in logs (mask phone, email)	Privacy

3. Sensitive data classification

Data	Classification	Key controls
Customer data (names, contacts, addresses, tax IDs)	Confidential — personal / business	Scope, encryption at rest, masking in logs
Credit information (limit, balance)	Confidential — financial	Limited to SM, Finance, Admin
Orders and prices	Confidential — commercial	Scope by role
Delivery addresses and GPS	Confidential — personal / location	Retention 90 days for GPS points
Driver information (licence, phone)	Confidential — personal	HR-level access
OTP	Secret	Hashed, short-lived
POD (signature, photo)	Confidential — personal	Signed URLs, retention 2 years
Invoices	Confidential — financial	Finance scope
Uploaded documents	Confidential	Virus scan, signed URLs
Permissions and audit	Restricted	Admin only

4. Package contents

Architecture **BM-SEC-002** (Security Architecture) · authentication and session **BM-SEC-003** (Authentication, Password, MFA and Session Management Design) · authorisation **BM-SEC-004**

(Authorization and RBAC Design) · RBAC / access matrix **BM-SEC-005** (RBAC and Access Control Matrix) · data protection **BM-SEC-006** (Data Protection, Encryption and Backup Security Policy) · privacy draft **BM-SEC-007** (Privacy Policy (Draft)) · audit and monitoring **BM-SEC-008** (Audit Logging and Security Monitoring Policy) · channel security **BM-SEC-009** (File Upload, OCR, OTP, Email and OpenWA Security) · incident response **BM-SEC-010** (Security Incident Response Plan) · vulnerability management and testing **BM-SEC-011** (Vulnerability Management and Security Testing Plan) · risk register **BM-SEC-012** (Security Risk Register).

Revision history

Version	Date	Author	Description
1.0	2026-11-12	Documentation team	Initial draft prepared from analysis of the bellomassi-premium-ui source code and existing project documents.